CS361 — Cybersecurity Project

Checkpoint 2

Baseline Analysis & Threat Modeling

AI-Assisted Phishing Detection for Healthcare Email Systems

Team Members

Sergio Olivas — Project Lead / Research

Khumbo Nyirenda — Data Collection

Cerilo Yousif — Development

Ernest Apollon — Development

Victor Olatunji — Documentation

April 12, 2026

GitHub Repository

https://github.com/SergioOlivas1/CS361.git

1. System Workflow

Our project focuses on an AI-assisted phishing detection system designed for a small healthcare clinic email environment. The system sits between the external internet and employee inboxes, analyzing every incoming message before it reaches a user.

1.1 Workflow Stages

Stage	Description
Incoming Email	External email arrives at the clinic mail server from the internet.
Preprocessing	Sender address, reply-to field, links, and raw content are extracted.
Feature Extraction	Keywords, metadata, structural patterns, and URL characteristics are analyzed.
AI Detection Model	Extracted features are scored against known phishing patterns and indicators.
Risk Scoring	A numeric score (0–100) is calculated based on triggered flags and severity.
Classification	Score maps to one of three labels: Safe, Suspicious, or Phishing.
Output / Action	Safe → delivered; Suspicious → user warned; Phishing → quarantined.

1.2 System Architecture Diagram

The following diagram shows the complete email processing pipeline from intake to final classification and action.

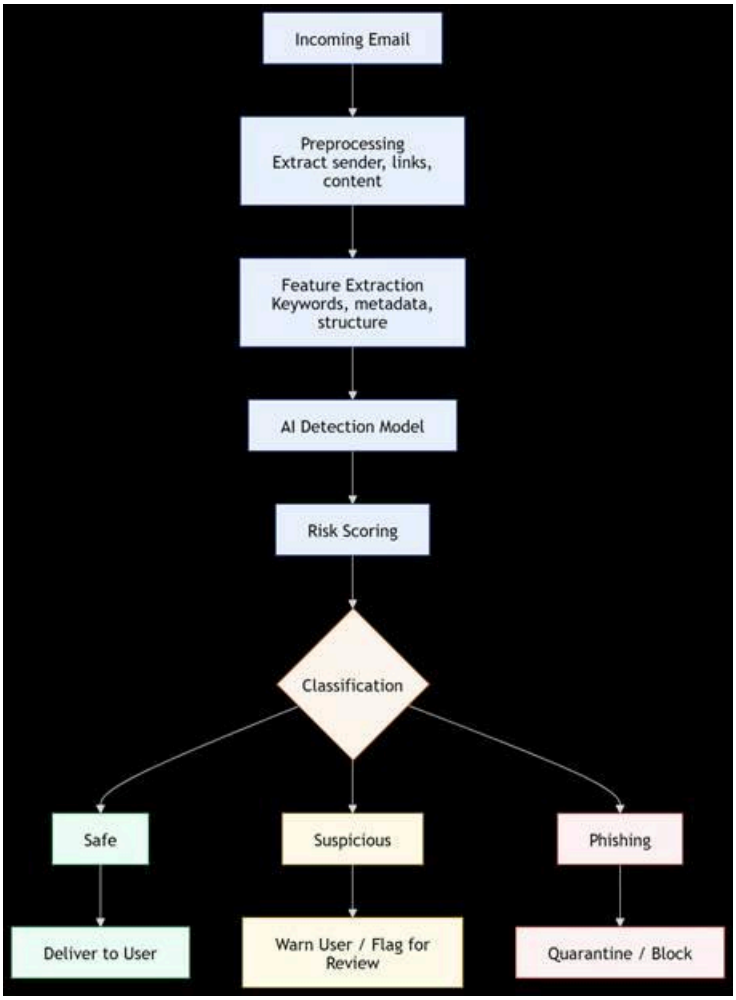
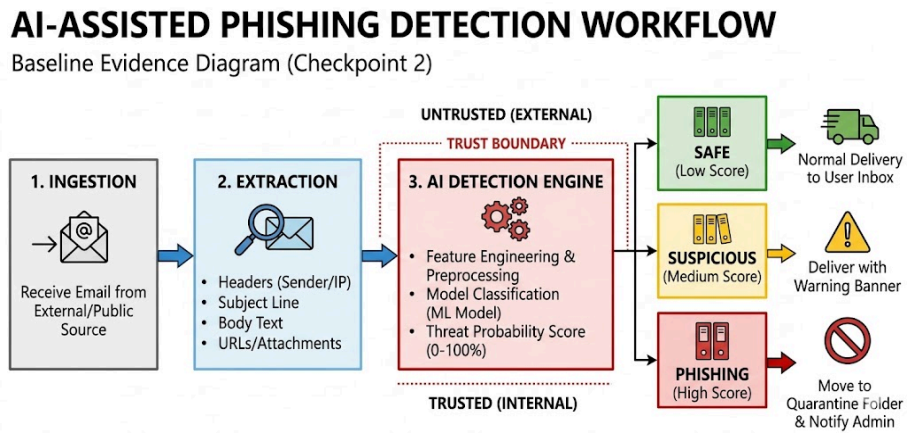


Figure 1 — System Architecture Diagram (docs/diagram.png)



2. Trust Boundaries & Data Flow

Trust boundaries are the points where data crosses from a less trusted zone into a more trusted one. Each boundary is a potential attack entry point.

Boundary	From (Untrusted)	To (Trusted)
External Email → Clinic Network	Public internet / unknown senders	Clinic mail server
Email System → AI Detection Model	Raw email data (unvetted)	Detection pipeline
AI Model → Employee Users	Model output / classification result	Employee inbox / workflow
Employee Devices → Internal Systems	User endpoint (can be compromised)	EHR, records, internal apps

3. Expanded Asset Inventory

The following assets have been identified as requiring protection within the clinic email environment.

Asset	Why It Matters	Priority
Patient Data	Highly sensitive health records; HIPAA-regulated.	**Critical**
Employee Credentials	Stolen logins enable account takeover and lateral movement.	**Critical**
Email Accounts	Primary attack surface; phishing emails land here first.	**High**
Email Server / System	Entry point for all external communication.	**High**
AI Detection Model	If evaded or manipulated, the entire protective layer fails.	**High**
Internal Network	A compromised endpoint can pivot into broader clinic infrastructure.	**High**
Email Attachments / Links	Most common malware delivery method in phishing campaigns.	**Medium**
Employee Trust in System	If users lose confidence in warnings, they ignore them.	**Medium**

4. Threat Model

4.1 Key Threats & Attack Surfaces

Threat	Attack Surface	Likely Impact
Phishing emails (healthcare lures)	Employee inbox	Credential theft, unauthorized access
Credential harvesting	Fake login pages in email links	Full account compromise, HIPAA breach
Malware via attachments	Email attachments (.pdf, .docx)	Ransomware, data loss, lateral spread
Social engineering	Employee psychology / trust	Voluntary credential disclosure
AI evasion / adversarial emails	AI detection model input	Phishing delivered undetected

4.2 Misuse / Abuse Scenarios

- **Scenario 1:** Employee receives a fake clinic billing email, clicks a link to a spoofed login page, and enters their credentials. Attacker gains access to their email and internal systems.
- **Scenario 2:** Attacker sends an email with a malicious attachment disguised as a patient referral document. Employee opens it, deploying malware on their workstation.
- **Scenario 3:** A carefully crafted email avoids all keyword triggers and bypasses AI detection. Phishing email is delivered to inbox with no warning.
- **Scenario 4:** Employee receives a flagged suspicious email but dismisses the warning and proceeds. Credentials are stolen.
- **Scenario 5:** An attacker compromises one employee account and uses it to send internal phishing emails to colleagues, exploiting established trust.

5. Baseline Condition

The following documents the current state of the project before any advanced defensive improvements are applied. This is the starting point from which all future improvements will be measured.

5.1 Current State

- Basic detection prototype implemented in Python (keyword + feature scoring)
- System workflow designed and diagrammed (see Section 1)
- GitHub repository initialized with documented structure (README, docs/, src/, data/)
- Sample phishing and legitimate email test cases defined and executed
- Initial risk scoring logic (0–100 scale) operational

5.2 What Is Not Yet Implemented

- No live email server integration
- No quarantine infrastructure (classification outputs action text only)
- No real-time logging or monitoring dashboard
- No advanced ML model (current system is rule/keyword-based)
- No user-facing warning UI
- No MFA enforcement

5.3 Baseline Evidence Summary

Evidence Item	Description
System Architecture Diagram	Full pipeline flowchart embedded in Section 1 above (docs/diagram.png)
VS Code + Script Screenshot	Source code view of phishing_detector.py open in VS Code (Section 6)

Terminal Output Screenshots	5 screenshots showing live script execution and all test case results (Section 6)
GitHub Repository	Initialized repo with README, docs/, src/, and data/ structure
README.md	Project overview, scope, team roles, asset list, threat assumptions, system flow
phishing_detector.py	Working Python detection script — keyword scoring, sender/URL pattern analysis
Test Cases (5 emails)	Defined inputs with expected and actual outputs, all passing (Section 6)

6. Initial Test Cases & Detection Output

The following test cases were run through phishing_detector.py. All screenshots below are direct captures of the script executing in VS Code on a Windows machine.

6.1 Test Case Summary Table

Test	Sender / Subject	Key Flags	Expected	Result
TC-01	billing@yourclinic.org / Appointment confirmed Tuesday	None	Safe	**Safe — 0/100**
TC-02	no-reply@medicare-update.xyz / URGENT: Portal SUSPENDED	Phishing keyword, healthcare lure, bad sender, bad URL	Phishing	**Phishing — 75/100**
TC-03	support@insurance-verify.click / Insurance Verification Required	2 keywords, healthcare lure, bad sender, bad URL, attach	Phishing	**Phishing — 90/100**
TC-04	hr@yourclinic.org / Staff meeting notes attached	Attachment only	Safe	**Safe — 10/100**
TC-05	noreply@123456789@mail.com / Security Alert	4 phishing keywords, malformed sender	Phishing	**Phishing — 80/100**

All 5 test cases produced the expected classification. 0 false positives, 0 false negatives across the test set.

6.2 Live Script Execution — Screenshots

The following screenshots show the actual output of phishing_detector.py running in the VS Code terminal.

```
PROBLEMS   OUTPUT   DEBUG CONSOLE   TERMINAL   PORTS                                   Python Debug Console

PS C:\Users\Owner\Downloads>  & 'c:\Users\Owner\AppData\Local\Programs\Python\Python312\python.exe' 'c:\Users\Owner\.vscode\extensions\ms-python.debugpy-2025.18.0-win32-x64\bu
ndled\libs\debugpy\launcher' '62162' '--' 'C:\Users\Owner\Downloads\phishing_detector.py'


  ==================================================
    FROM    : noreply@123456789@mail.com
    SUBJECT: Security Alert: Suspicious activity on your account
  ==================================================
    CLASSIFICATION : Phishing
    RISK SCORE     : 80/100
    ACTION         : Quarantine immediately. Do not deliver.
    FLAGS:
      - Phishing keyword detected: 'reset your password now'
      - Phishing keyword detected: 'security alert'
      - Phishing keyword detected: 'suspicious activity'
      - Phishing keyword detected: 'immediate response required'
      - Suspicious sender pattern: noreply@123456789@mail.com

PS C:\Users\Owner\Downloads>
```

Figure 2 — VS Code showing phishing_detector.py source code and TC-01 (Safe, 0/100) beginning execution

```
PROBLEMS   OUTPUT   DEBUG CONSOLE   TERMINAL   PORTS                                   Python Debug Console

PS C:\Users\Owner\Downloads>  & 'c:\Users\Owner\AppData\Local\Programs\Python\Python312\python.exe' 'c:\Users\Owner\.vscode\extensions\ms-python.debugpy-2025.18.0-win32-x64\bu
ndled\libs\debugpy\launcher' '62162' '--' 'C:\Users\Owner\Downloads\phishing_detector.py'
  ==================================================
    CLASSIFICATION : Safe
    RISK SCORE     : 10/100
    ACTION         : Deliver to inbox.
    FLAGS:
      - Email contains attachment


  ==================================================
    FROM    : noreply@123456789@mail.com
    SUBJECT: Security Alert: Suspicious activity on your account
  ==================================================
    CLASSIFICATION : Phishing
    RISK SCORE     : 80/100
    ACTION         : Quarantine immediately. Do not deliver.
    FLAGS:
      - Phishing keyword detected: 'reset your password now'
```

Figure 3 — TC-02: no-reply@medicare-update.xyz classified as Phishing (75/100), 5 flags triggered

```
PROBLEMS   OUTPUT   DEBUG CONSOLE   TERMINAL   PORTS                                   Python Debug Console

PS C:\Users\Owner\Downloads>  & 'c:\Users\Owner\AppData\Local\Programs\Python\Python312\python.exe' 'c:\Users\Owner\.vscode\extensions\ms-python.debugpy-2025.18.0-win32-x64\b
ndled\libs\debugpy\launcher' '62162' '--' 'C:\Users\Owner\Downloads\phishing_detector.py'
  ==================================================
    CLASSIFICATION : Phishing
    RISK SCORE     : 90/100
    ACTION         : Quarantine immediately. Do not deliver.
    FLAGS:
      - Phishing keyword detected: 'update your billing'
      - Phishing keyword detected: 'validate your credentials'
      - Healthcare lure detected: 'insurance verification'
      - Suspicious sender pattern: support@insurance-verify.click
      - Suspicious URL pattern detected in body
      - Email contains attachment


  ==================================================
    FROM    : hr@yourclinic.org
    SUBJECT: Staff meeting notes attached
  ==================================================
```

Figure 4 — TC-03: support@insurance-verify.click classified as Phishing (90/100), 6 flags triggered; TC-04 beginning

```
PROBLEMS   OUTPUT   DEBUG CONSOLE   TERMINAL   PORTS                                   Python Debug Console

PS C:\Users\Owner\Downloads>  & 'c:\Users\Owner\AppData\Local\Programs\Python\Python312\python.exe' 'c:\Users\Owner\.vscode\extensions\ms-python.debugpy-2025.18.0-win32-x64\bu
ndled\libs\debugpy\launcher' '62162' '--' 'C:\Users\Owner\Downloads\phishing_detector.py'
  SUBJECT: URGENT: Patient portal access will be SUSPENDED
 ==================================================
  CLASSIFICATION : Phishing
  RISK SCORE     : 75/100
  ACTION         : Quarantine immediately. Do not deliver.
  FLAGS:
    - Phishing keyword detected: 'confirm your identity'
    - Healthcare lure detected: 'patient portal'
    - Suspicious sender pattern: no-reply@medicare-update.xyz
    - Suspicious URL pattern detected in body
    - High urgency detected in subject (2 all-caps words)


 ==================================================
  FROM   : support@insurance-verify.click
  SUBJECT: Insurance Verification Required
 ==================================================
```

Figure 5 — TC-04: hr@yourclinic.org classified as Safe (10/100), attachment-only flag; TC-05 beginning

```
C: > Users > Owner > Downloads > phishing_detector.py > ...
57  class Email:
58      sender: str
59      subject: str
60      body: str
61      has_attachment: bool = False
62
63  @dataclass
64  class DetectionResult:
65      classification: str       # "Safe", "Suspicious", or "Phishing"
66      risk_score: int           # 0-100
67      triggered_flags: List[str]
68      recommended_action: str
69
70
71  # ──────────────────────────────────────────
72  #  Detection Engine
73  # ──────────────────────────────────────────

PROBLEMS   OUTPUT   DEBUG CONSOLE   TERMINAL   PORTS                                   Python Debug Console

PS C:\Users\Owner\Downloads>  & 'c:\Users\Owner\AppData\Local\Programs\Python\Python312\python.exe' 'c:\Users\Owner\.vscode\extensions\ms-python.debugpy-2025.18.0-win32-x64\bu
ndled\libs\debugpy\launcher' '62162' '--' 'C:\Users\Owner\Downloads\phishing_detector.py'

  ┌──────────────────────────────────────────────┐
  │  AI-Assisted Phishing Detection System — CS361
  │  Healthcare Clinic Email Environment
  └──────────────────────────────────────────────┘


 ==================================================
  FROM   : billing@yourclinic.org
  SUBJECT: Your appointment is confirmed for Tuesday
 ==================================================
  CLASSIFICATION : Safe
  RISK SCORE     : 0/100
  ACTION         : Deliver to inbox.


 ==================================================
  FROM   : no-reply@medicare-update.xyz
```

Figure 6 — TC-05: noreply@123456789@mail.com classified as Phishing (80/100), 5 flags triggered

7. Initial Risk Matrix

Risk	Likelihood	Impact	Risk Level
Phishing email bypasses AI detection	High	High	**Critical**
Credential theft via fake login page	High	High	**Critical**
Malware delivered via attachment	Medium	High	**High**
AI evasion (adversarial email crafting)	Medium	High	**High**
Employee ignores warning notification	Medium	Medium	**Medium**
Compromised account used to phish internally	Low	High	**Medium**

8. Planned Controls

The following defensive controls are planned for evaluation and implementation in subsequent checkpoints.

Control	Description	Addresses
Improved AI Detection Model	Expand beyond keywords to include sender reputation, header analysis, and ML scoring	AI evasion, bypass
Email Filtering Rules	Block/flag emails with bad domains, IP links, URL shorteners, suspicious patterns	Phishing delivery
Quarantine System	Automatically isolate Phishing-classified emails until reviewed by IT	Malware, credentials
User Warning Notifications	Display clear in-inbox banners for Suspicious emails before user interaction	Employee behavior
Multi-Factor Authentication	Require second factor for all clinic accounts to limit credential theft damage	Credential theft
Logging & Monitoring	Record all classification decisions and flag anomalies for IT review	All threats
Employee Awareness Training	Brief staff on recognizing phishing lures specific to healthcare environments	Social engineering